

[대외비] (주)해랑금융 수탁자 현황 자료

1. 수탁자 기본 현황

- 회사명: (주)해랑금융 (Haerang Financial Services Inc.)
- 대표자: 강민준
- 설립일: 2017년 9월 1일
- 소재지: 서울특별시 강남구 테헤란로
- 직원 수: 총 98명 (정보보호팀 9명, IT개발팀 22명, 운영·기획 67명)
- 주요 사업: 항공 마일리지 연계 결제 API 중계, 금융 데이터 처리·정산
- 인증 현황: ISO 27001 인증 보유, PCI-DSS Level 1 준수
- 개인정보보호책임자(CPO) 및 정보보호 최고책임자(CISO) 각각 별도 지정, 법적 자격 요건 충족

2. 개인정보 위탁 업무 내역

- 위탁자: (주)하랑항공 (위탁 담당부서: 디지털결제혁신팀)
- 위탁 업무: 하랑항공 마일리지 연계 결제 서비스 API 중계 및 금융 데이터 처리
 - 항공 마일리지 사용 결제 요청 API 중계 처리 (실시간 승인·취소)
 - 결제 이력 데이터 수신·저장·정산 처리
 - 마일리지 정산 파일 생성 및 SFTP 전송
 - 카드사 연동 결제 토큰화(Tokenization) 처리
- 계약 기간: 2025년 02월 01일 ~ 2026년 02월 01일 (1년, 연간 자동 갱신 조항 포함)
- 개인정보 재위탁 현황
 - (주)한길 회계법인: 마일리지 정산 배치
 - (주)하랑항공 사전 서면 승인 문서 부재, 구두 승인만 확인
 - 재위탁 계약서 내 개인정보보호 조항 미포함

3. 처리하는 개인정보 항목 및 규모

- 데이터 접근 방식
 - (A) 하랑항공 연동 데이터: mTLS + TLS 1.3 API 채널 및 SFTP(PGP 암호화)를 통해 결제·정산 데이터를 수신하여 처리
 - (B) 수탁자 자체 시스템: 결제 DB·API Gateway·SFTP 서버를 On-premise 및 클라우드(AWS) 혼합 환경으로 운영
- 처리 개인정보 항목

- 성명, 회원 ID (하랑항공 마일리지 회원)
- 계좌번호 (AES-256 암호화 저장)
- 카드번호 토큰 (PCI-DSS 기준 토큰화 처리, 원번호 미보관)
- 결제 이력 (결제일시·금액·승인번호·가맹점 정보)
- OAuth 인증 토큰 (API 연동 세션 식별용)
- 마일리지 정산 파일 내 정산 대상 회원 식별 정보
- 규모
 - 월평균 결제 API 처리 건수: 약 45만 건
 - 결제 DB 보관 이력(90일 기준): 약 1,350만 건
 - ※ 결제 DB 90일 자동 삭제 배치가 3개월째 오류 상태로 보유기간 초과 데이터가 미파기 상태로 잔존 (개인정보보호법 위반)

4. 개인정보 처리 시스템 현황 (논리적 망분리 환경)

- 시스템 구성
 - API Gateway: 하랑항공 결제 요청 수신 및 카드사 중계 처리 (AWS 기반, Active-Standby 이중화)
 - 결제 DB: 결제 이력·정산 데이터 저장 (PostgreSQL, Active-Standby 이중화, 오프사이트 백업 적용)
 - SFTP 서버: 마일리지 정산 파일 송수신 전용 (On-premise, PGP 암호화 전송)
 - NAS 공유드라이브: 내부 업무 파일 저장 (On-premise)
- ※ SFTP 서버 마지막 OS 보안패치 적용일이 5개월 전 — CVE 취약점 3건 미패치 상태로 잔존
- 네트워크 (논리적 망분리)
 - 논리적 망분리 적용, 개인정보처리시스템(결제 DB·API 서버)과 인터넷망 분리·운영
 - DMZ 구간에 API Gateway·SFTP 서버 배치, 내부 결제 DB와 별도 방화벽으로 구분
 - √ 업무망 접근은 IPSec VPN + OTP(TOTP) 이중 인증 후 허용
 - √ 하랑항공 연동 구간은 mTLS + TLS 1.3 전용 채널 사용
 - URL 필터링·비인가 프로그램 차단 정책 적용 중이나, SSL Inspection 미적용으로 HTTPS 경유 개인 클라우드 접속·파일 업로드 탐지·차단 불가. 이메일 DLP만 적용, 웹·엔드포인트 DLP 미도입

5. (자체 점검) 보안 관리 현황

5.1 내부 관리 계획 및 조직

- 개인정보보호 내부관리계획서 대표이사 결재 완료. PCI-DSS·전자금융거래법 연계 항목 포함, 연 1회 정기 검토·갱신 이력 확인
- 내부관리계획서 공표(이메일·그룹웨어) 실시. 직원 구두 질의시 암호화 기준·사고 보고 절차 등 핵심 내용 답변 미흡

- 위탁사 핫라인(하랑항공 담당자 비상 전화번호) 비상연락망 미등재. API Key 유출 전용 대응 절차 없음, 모의훈련 미 실시, 하랑항공 통보 SLA(4시간) 미명시
- 재해·재난 매뉴얼 및 BCP 완비. 분기 1회 복구 테스트 실시, 결제 DB Active-Standby 이중화 구성
- CISO·CPO 각각 별도 지정, 법적 자격 요건(정보보호법 제13조) 충족. 개인정보처리방침 내 CPO 성명·연락처 기재
- 개인정보취급자 명단 HR 시스템과 월 단위 대조, 최소화 원칙 준수. 파견·외주 인력 포함 최신 관리 확인
- 신규 입사자·퇴사자·외주·파견 인력 보안서약서 미징구
- 전체·신규 입사자·직무별 연 2회 교육 실시, 이수율 100%. PCI-DSS·API 보안·전자금융거래법 특화 모듈 포함, 온라인 퀴즈 효과 측정 운영 확인

5.2 접근 통제 및 권한 관리

- API Gateway 계정 목록에 6개월 전 퇴직한 외주 인력 계정 1건 잔류. 개인정보취급자 명단 미등재된 계정 존재 여부 확인
- 역할 기반 접근통제(RBAC) 체계 문서 존재하나 실제 적용 불일치. API 개발팀 5명 중 3명이 운영 결제 DB 직접 접근 권한 보유
- ITSM 기반 4단계 승인 워크플로우(신청→팀장→정보보호팀→IT 발급) 운영. 승인 없는 직접 계정 발급 여부 테스트 기술적 차단 확인
- 퇴사자 4명 중 1명 HR 연동 오류로 퇴사 후 4일 경과 후 계정 말소. 부서이동 후 3개월 경과 직원 1명의 구 부서 결제 DB 조회 권한 미회수 잔류
- 계정·권한 이력 AWS S3 Object Lock(3년 retention) WORM 보관, 위변조 방지 적용 확인
- 결제 DB·API Gateway·SFTP 서버 모두 1인 1계정 원칙 준수. 배치 서비스 계정은 시스템 전용으로 분리, 개인 로그인 불가 구조 확인
- 세션 타임아웃 결제 DB 콘솔 15분·API Gateway 콘솔 10분, 타임아웃 후 MFA 재인증 구조 전사 강제 적용
- 결제 DB 콘솔·API Gateway 5회 실패 시 계정 15분 잠금, 잠금 해제 시 OTP 또는 관리자 직접 확인 절차 완비. 로그인 실패 이벤트 SIEM 연동 확인

5.3 접속기록 보관 및 점검

- 결제 DB·API Gateway·SFTP 서버 법령 요구 6개 항목(식별자·접속일시·IP·처리 정보주체·수행업무·조회건수) 완전 기록. API 호출 로그 엔드포인트·처리 건수·응답코드 추가 포함. WORM 스토리지 저장
- SIEM 실시간 이상탐지 운영 중이나 임계치 기준 내부 규정 미명시, 담당자 경험 기반 운영. 탐지 이벤트 로그 존재하나 검토·처리 결과 보고서 미작성, 월 1회 정기 검토 보고서 미작성
- API 호출 로그·결제 DB 접속기록 2년 이상 보관, 고유식별정보 처리 기준 의무 충족. 실제 2년 전 로그 정상 조회 확인

- WORM 스토리지(AWS S3 Object Lock, Compliance Mode, 2년 retention) 자동 저장. 관리자 수정·삭제 기술적 차단, 해시값 무결성 검증 적용

5.4 비밀번호 관리

- 비밀번호 정책 결제 DB 콘솔(3종류 10자리, 90일), API Gateway(2종류 8자리) 법령 기준 충족
- 레거시 모니터링 콘솔 비밀번호 유효기간 미설정, 최장 14개월 미변경 계정 2건 확인. 임시 비밀번호 발급 후 강제 변경 일부 시스템 미적용
- 화면보호기 10분·비밀번호 잠금 GPO 전사 적용 확인

5.5 접속 보안 및 네트워크

- 외부 접속 시 IPSec VPN + OTP(TOTP) MFA 강제 적용. 하랑항공 연동 구간 mTLS + TLS 1.3, 방화벽 직접 접근 차단 확인
- 방화벽·IPS 설치 완비. DMZ(API Gateway·SFTP)와 내부 DB 별도 방화벽 구분, 분기 1회 정책 검토 운영
- 논리적 망분리 완전 적용, 예외 구간 없음. 분기 1회 방화벽 정책 검토 이력 확인
- URL 필터링(카테고리 기반) 및 비인가 프로그램 설치 차단 정책 적용
- SSL Inspection 미적용으로 HTTPS 경유 개인 클라우드(Google Drive 등) 파일 업로드 탐지·차단 불가. 테스트 시 차단 없이 업로드 성공 확인
- HTTPS 우회 경로를 통한 개인 클라우드 파일 업로드 차단 불가, DLP 미도입으로 개인정보 유출 탐지 수단 부재
- 무선랜 WPA3 + WIPS 적용. 업무용·게스트 VLAN 완전 분리, 비인가 AP 탐지·차단 이력 확인

5.6 단말기 보안

- 2025.10 외부 전문업체 취약점 점검 실시, High 2건 발견 후 30일 이내 전건 조치 완료, 재점검 통과 확인
- 전 서버(API·결제 DB·SFTP) 백신 설치, 자동 업데이트·실시간 감시 활성화. 중앙 관리 콘솔 모니터링 운영
- 주요 서버(API·결제 DB) 월 1회 정기 패치 양호. SFTP 서버 마지막 패치 5개월 전, CVE 3건 미패치
- SFTP 폴더 등록 IP 접근 + PGP 암호화 적용. NAS '결제정산_2025' 폴더 전체 임직원 읽기 권한, 결제 이력 파일 12건 평문 저장하여 접근 제한·암호화·로깅 미조치
- 전 단말 백신 설치, MDM 컴플라이언스 기준 미준수 0건. 자동 업데이트·실시간 감시 활성화
- WSUS 자동 패치 배포 운영 중, 승인 만료 예외 단말 2건 네트워크 격리 등 대체 통제 미적용 상태로 운영 중
- GPO로 전 단말 USB 포트 쓰기 차단. 승인된 암호화 USB 화이트리스트 허용, 최근 1개월 무단 연결 시도 3건 탐지·차단 확인

5.7 개인정보 암호화 및 출력 통제

- 사용자 비밀번호 bcrypt(cost factor 12) 적용, MD5-SHA-1 등 취약 알고리즘 미사용. 전 시스템 동일 기준 적용
- 카드번호 PCI-DSS 기준 토큰화(원번호 미보관), 계좌번호·결제이력 AES-256 + HSM 암호화 저장
- API-SFTP 주요 구간 mTLS + TLS 1.3 / PGP 암호화 적용. 관리자 PC↔결제 DB 콘솔 접속 구간 HTTP(비암호화) 통신 확인
- 전 업무용 단말 BitLocker 디스크 암호화 적용. 재택 단말 포함 적용 확인
- 암호화 키 관리 절차서 완비, AWS KMS + HSM 기반 관리. Primary/Backup 2인 담당 체계, 연 1회 키 로테이션 이력 확인
- 계좌번호·카드번호·결제이력 조회 화면 마스킹 적용(계좌 뒤 4자리 외, 카드 중간 8자리). JIT 팀장 승인 후 30분 임시 해제, 엑셀 다운로드 시 마스킹 유지 확인
- 결제 이력 관련 출력물 관리대장 미기재 항목 확인. 점검 당일 결제 승인 내역 출력물 프린터 트레이 방치 확인. 출력 DLP 미적용, 보안 출력 솔루션 미도입

5.8 개인정보 생명주기

- 계약 범위 내 최소 수집 원칙 준수. DB 스키마 대조 결과 계약서 범위 초과 항목 수집 없음 확인
- 하랑항공 전용 DB 스키마 분리 운영. 내부 모니터링 계정 2개가 하랑항공 DB·기타 테스트 DB 모두 접근 가능한 권한 범위 과도 상태 확인
- 마일리지 정산 배치 처리 (주)한길 회계법인 재위탁. 계약서 개인정보보호 조항 포함. 하랑항공 서면 승인 없이 구두 승인만으로 진행, 서면 증빙 부재
- 반출 관리대장 기재율 누락. 팀장 승인 없이 이메일로 결제 데이터 외부 발송 사례 발견
- 전자 파일 Crypto Erase 자동 파기(마일리지 정산 2시간 이내, 계좌 원문 즉시). 파기 대장·자동 파기 배치 로그 관리
- 결제 이력 90일 자동 삭제 배치 설정되어 있으나, 3개월 전 스크립트 오류 발생 후 인지 못한 채 방치하여 90일 초과 데이터 미파기 잔존. 오류 알림 체계 미설정
- 파쇄기 운영 중이나 파기 이력 대장 없음. 파쇄 대기 문서함에 결제 내역 출력물 최장 3일 경과 방치. 업무 종료 후 즉시 파기 원칙 미준수
- 결제 승인 이력 전자금융거래법 기준 5년 보관 분리 DB 운영, 보관 기간 경과 후 자동 파기 체계 완비

6. 개인정보 재위탁 현황

- (주)한길 회계법인: 마일리지 정산 배치 처리 업무
- (주)하랑항공 사전 서면 승인 문서 부재, 구두 승인만 확인
- 재위탁 계약서 내 개인정보보호 조항 미포함